Introduction à la cybersécurité

Corrigé d'examen

Source : examen-2024-01-26.pdf · 20 questions

La correction officielle indique les réponses par des cases noircies.

Question 1 · B, F, G La clé privée sert à signer et la clé publique à vérifier. Avec un schéma sûr, ni la clé publique ni des signatures observées ne permettent de retrouver la clé privée en pratique.

Ch. 2, signatures numériques, PDF p. 146–147.

Question 2 · B, D, E, F, G Un certificat X.509 contient un numéro de série, des informations sur le sujet, sa clé publique, une période de validité et la signature de l'émetteur. La clé publique de l'émetteur est obtenue séparément pour vérifier cette signature.

Ch. 3, certificats et PKI, PDF p. 184–185.

Question 3 · C, D Avec la clé publique authentique du destinataire, on peut protéger une clé de session sur un réseau observable. Le chiffrement symétrique est généralement plus rapide : il est utilisé ensuite pour les données.

À noter : Le réseau n'a pas besoin d'être confidentiel ; la clé de session, elle, doit le rester. Une clé publique non authentifiée permet une attaque de l'homme du milieu.

Ch. 2, chiffrement symétrique, PDF p. 119 ; ch. 3, échange de clés RSA, PDF p. 169–170.

Question 4 · A, E On forme une chaîne en appliquant plusieurs fois le même hachage à un secret. Chaque connexion révèle le maillon précédent : le serveur le hache une fois pour le comparer à son dernier maillon connu, puis met celui-ci à jour.

Ch. 4, jetons et schéma de Lamport, PDF p. 295–299.

Question 5 · B, C Avec une clé publique correctement liée à son propriétaire, la vérification établit l'origine du message et son intégrité. La signature seule ne chiffre pas le message et ne prouve pas qu'il est récent.

Ch. 2, signatures numériques, PDF p. 146–147 ; ch. 3, certificats et PKI, PDF p. 181–184.

Question 6 · E Deux messages différents de même empreinte forment une collision. Elle n'est ni une erreur ni une inversion du hachage : elle est inévitable si l'on considère toutes les entrées possibles.

Ch. 2, fonctions de hachage et collisions, PDF p. 97, 100.

Question 7 · E Deux facteurs distincts exigent que l'attaquant compromette deux formes de preuve, par exemple le mot de passe et la possession d'un appareil. L'un seul ne suffit pas.

Ch. 4, authentification à plusieurs facteurs, PDF p. 218–220.

Question 8 · A, C, D, E, G Le résolveur validant suit la chaîne de confiance des clés KSK et ZSK et vérifie les enregistrements reçus. Il peut ainsi rejeter les réponses forgées qui serviraient à usurper une réponse DNS ou à empoisonner son cache. DNSSEC ne chiffre pas les données et ne garantit pas à lui seul le dernier saut jusqu'au client.

Ch. 5, sécurité DNS, PDF p. 487–491, 527–528.

Question 9 · C On démontre qu'on connaît un secret sans communiquer le secret lui-même. Dans l'exemple du cours, le serveur fait vérifier un défi signé sans demander la clé privée.

Ch. 4, preuve à divulgation nulle, PDF p. 223.

Question 10 · A On récupère le sel associé au compte, on recalcule l'empreinte avec le mot de passe fourni et les mêmes paramètres, puis on compare au résultat stocké.

Ch. 4, stockage et salage des mots de passe, PDF p. 242–245.

Question 11 · A, C, E, F Une empreinte doit être facile à calculer, mais difficile à inverser, à reproduire après modification ou à faire coïncider pour deux messages choisis. La sûreté de l'algorithme ne doit pas dépendre du secret de sa description.

Ch. 2, propriétés du hachage, PDF p. 97 ; ch. 1, principes de Kerckhoffs, PDF p. 67.

Question 12 · D Une autorité de certification est un tiers de confiance qui émet et signe des certificats. Sa signature lie une clé publique à l'identité déclarée de son détenteur.

Ch. 3, certificats et PKI, PDF p. 181–184.

Question 13 · A L'emplacement dans le réseau ne suffit pas à prouver une identité. En supprimant l'authentification pour les connexions internes, le service accorde une confiance implicite contraire au modèle Zero Trust.

Ch. 5, sécurité de la topologie réseau, PDF p. 424.

Question 14 · B, D, E Un code généré automatiquement évite les choix humains prévisibles. Son usage unique ou sa durée limitée réduit la possibilité de réutiliser une valeur trouvée et limite le temps disponible pour tenter de la deviner.

À noter : B est retenue dans le corrigé 2024. La résistance à la force brute dépend aussi de la taille du code, de sa durée de validité et des limites imposées au nombre d'essais.

Ch. 4, mots de passe à usage unique, PDF p. 294–295, 304.

Question 15 · B, C Des transformations bien combinées peuvent brouiller la distribution observable et diffuser l'effet d'une petite variation du texte clair. On rend ainsi plus difficile la correspondance entre les fréquences du texte clair et celles du chiffré.

À noter : La transposition seule conserve les fréquences des symboles. Une substitution monoalphabétique seule en change l'étiquette, mais conserve le profil des fréquences.

Ch. 2, effet avalanche et analyse fréquentielle, PDF p. 90–91, 115, 124.

Question 16 · D Le hachage calculé par le client est une preuve réutilisable : si un attaquant le récupère à une extrémité, il peut le présenter à la place de l'utilisateur. TLS protège le transport, mais ne transforme pas cette valeur fixe en preuve à divulgation nulle et ne corrige pas le choix humain du mot de passe.

Ch. 4, preuve à divulgation nulle, stockage et jetons, PDF p. 223, 242–245, 294–295 ; ch. 5, tunnel TLS, PDF p. 379–380.

Question 17 · A Le mot de passe est un facteur de connaissance ; l'empreinte est un facteur biométrique. Deux réponses mémorisées ne forment pas deux catégories de facteurs.

Ch. 4, facteurs d'authentification, PDF p. 218–220.

Question 18 · B, D, E, F Dans le cas HTTPS usuel, TLS authentifie le serveur, protège la confidentialité et l'intégrité du trafic et empêche de rejouer ses enregistrements dans le tunnel établi. L'authentification du client n'est pas requise par défaut.

Ch. 5, HTTPS et tunnels TLS, PDF p. 379–380.

Question 19 · B Un certificat racine représente l'autorité à laquelle le client choisit de faire confiance. Il sert de point de départ pour vérifier les signatures dans la chaîne jusqu'au certificat présenté.

Ch. 3, chaîne de confiance et certificat racine, PDF p. 203–204.

Question 20 · C La sécurité doit subsister même si le fonctionnement du système est public. Pour le déchiffrement, la clé est le seul élément qui doit demeurer secret.

Ch. 1, principes de Kerckhoffs, PDF p. 67.